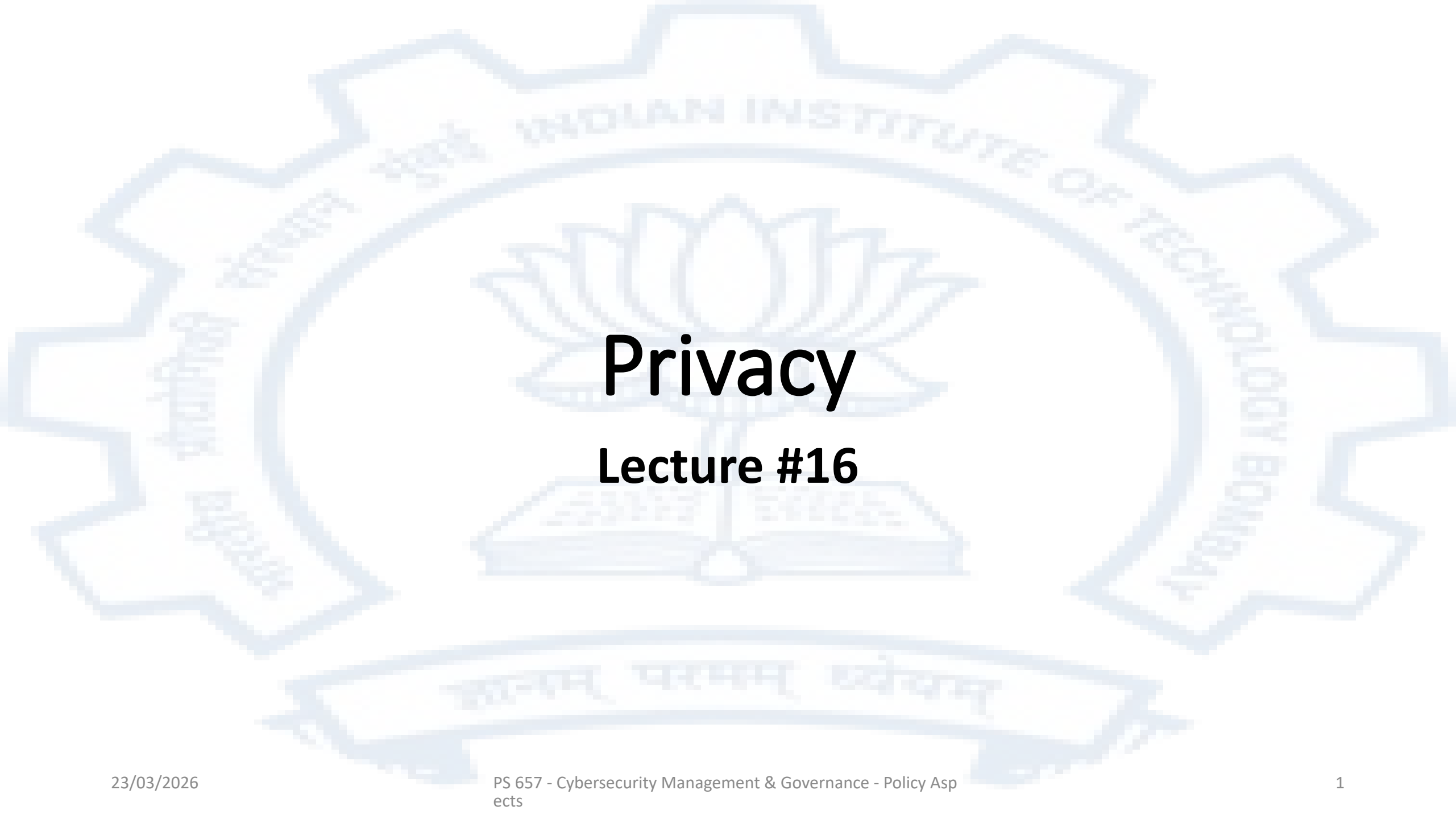




Privacy

Lecture #16

Privacy

The broadest conception of privacy is the right to be left alone or the right not to be disturbed

- Privacy is a property of an individual
- Information about that individual may be stored as data in various storage media
- Information about an individual may be implicitly inferred from some actions of the individual
- In the context of electronic interactions privacy is often reduced to the protection of data about the individual

Privacy viewed as confidentiality

One technical interpretation of privacy is to avoid making personal information available to any unauthorized entity and in particular the wider public. Under this interpretation of privacy, the objective of privacy technologies is to enable the use of services while minimizing the exposed information.

The exposed information here refers to both

- The information exposed explicitly to use the service
- The information exposed implicitly such as the frequency, location and time of usage

Protecting Data

From the confidentiality standpoint there are three broad scenarios

- An unauthorized entity manages to steal data from some data storage location
- Party A sends data to Party B for some purpose and Party A trusts Party B. Here from the confidentiality standpoint what is needed is to protect the data in transit and what is needed to prevent eavesdroppers from obtaining useful metadata about the communicating parties
- Party A sends data to Party B for some processing and does not trust Party B completely
 - No trust
 - Limited trust

Protecting data in transit

The use of E2EE (End to end encryption) in communication and messaging protocols can prevent third parties from accessing the data.

Most modern messengers like WhatsApp, Signal, Facebook messenger and Viber provide E2EE communication capabilities

Controlling access to data

When providing data to an untrusted/partially trusted entity there are two major methods of controlling access to the data

- Cryptographic methods
- Obfuscation methods

Obfuscation techniques

- Anonymization – decouple the identity from information
- Generalization – reducing the precision of elements of the data
- Suppression – suppressing part of the data set
- Dummy addition – adding dummy data to the dataset
- Perturbation – data is perturbed with noise of some chosen type

Metadata protection

Traffic metadata : Data about senders, receivers, routes, times etc

- A major technique is the use of anonymous communication networks like TOR or LOOPIX

Device metadata

- Type of device, OS and version, application being used, fonts installed etc collected to “fingerprint” a specific device. Fingerprinting is very hard to defend against

Location metadata

- User’s geographical location revealed either to explicit calls to location based services or through knowing the details of the access point to the network they are connected to

Privacy as Control

A wider notion of privacy over just that of confidentiality is being able to control what is done with data that is revealed. In this view a user is seen as needing the ability to control how much and to whom data is revealed, and what the receiving party may do with it.

Some mechanisms to do this are

- Support for privacy settings configuration
- Support for privacy policy negotiation
- Support for privacy policy interpretability

Privacy as transparency

Privacy as transparency refers to the design paradigms where the user is given feedback of what might happen when they make certain choices or carry out certain actions or run audits to determine if there has been a violation of privacy

- Feedback-based transparency
 - Privacy mirrors
 - Privacy nudges
- Audit
 - Relies on analysis of logs of activity
 - Logging activity may itself introduce additional privacy concerns

International norms

- Privacy is widely recognized as a conditional human right which may be subject to some limitations and exceptions
- Article 12 of the Universal Declaration of Human Rights in 1948 states that *'No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence...'*
 - This statement clearly contemplates the fact that some interference, i.e. that which is not arbitrary, may be legitimate
- In the narrower context of limiting government authority, the 4th Amendment to the US constitution states that *'The right of the people to be secure in their persons houses, papers, and effects, against unreasonable searches and seizures, shall not be violated, and no warrants [authorizing search or seizure] shall issue, but upon probable cause. . . '*
 - Here again the right extends to searches and seizures that are not unreasonable

Evolving interpretations

- In 1928 the US Supreme Court interpreted the 4th amendment narrowly as protecting people only from physical intrusions onto their property
- In 1967 the same US Supreme Court observed that *'laws like the 4th amendment are intended to **protect people not places**'* and re-interpreted the 4th amendment to protect people from unwarranted intrusion into electronic communications
- By the early 21st century it appears to be widely (almost universally) accepted that privacy protections, whatever they may be, extend to information in intangible form in cyberspace as well as in physical space

Current approaches

- Some countries regulate only government interference in private affairs of citizens while others provide a more general right of privacy in almost every situation
- The expectation of privacy may depend upon the relationship between the parties
 - A parent of a minor child will usually have a greater capability to interfere with the child as compared to an employer with an employee
- Some societies may view a certain type of intrusion as acceptable whereas in some the same thing may be viewed as a violation of human rights
- Some jurisdictions may specify the degree of interference very narrowly while in some the interference permitted may be quite broad

Treatment of metadata

- Privacy laws may treat metadata differently from the content based on the theory that people may have a lower expectation of privacy of metadata. This position is increasingly coming under criticism and courts and policy makers may need to reconsider the nature of metadata and its protection
- The concerning characteristics from the privacy standpoint are
 - the private quality of some information disclosed by modern metadata such as URLs
 - the incredible growth in the volume and types of metadata available in the age of ubiquitous personal mobile data communications
 - the growing volume of otherwise-private information that can be inferred from metadata using modern traffic analysis and visualization techniques

Interception by the State

- Usually justified by the need for law enforcement and security of the state (lawful interception)
- States may follow widely varying approaches and there is no apparent harmonization of approaches
- The State usually imposes at least the following on public communications providers
 - procuring and maintaining facilities designed to facilitate lawful interception within the service provider's domain (this obligation may be imposed under telecommunication regulation as a condition of telecommunications licensing, especially for those that operate in-state physical infrastructure such as PSTN operators);
 - providing technical assistance in response to lawful interception requests; and
 - maintaining the secrecy of the content of lawful interception requests, especially the identity of investigation targets.
- The ubiquitous availability of easy-to-use cryptographic techniques and the emergence of “virtual” communication providers (over the top providers) have created difficulties for law enforcement and licenced communications providers

Interception by non-state actors

- Interception by a public telecommunications provider in its own network
- Interception by any person of a communication transiting a third party network
 - This may also be criminalized as computer intrusion
- Interception of communication in a private network by the owners
 - May be governed by general privacy regulations

A brief history of privacy efforts in India

- 29th Sept 2011 – A group of experts is constituted chaired by Justice A.P. Shah to draw up a privacy framework for India
- 24th August 2017 – A 9 judge bench of the Supreme Court of India delivers a landmark judgement holding that every citizen of India has a fundamental right to privacy which was guaranteed by the Constitution of India within Article 21 in particular and Part III on the whole. This judgement has come to be known as the Puttaswamy judgement.
- In response to the judgement the Government of India sets up the Srikrishna Committee with the following terms of reference
 - a) To study various issues relating to data protection in India
 - b) To make specific suggestions for consideration of the Central Government on principles to be considered for data protection in India and suggest a draft data protection bill.

Timeline of litigation

- 2012 – Petition filed by Justice K.S. Puttaswamy (retired) and Mr. P. Khanna, in the Supreme Court of India, stating that Aadhaar violated fundamental rights like privacy and equality.
- 2015 – A 3 judge bench hears the petition and rules that the court must decide if the Indian Constitution grants citizens a fundamental right to privacy. This is initially referred to a 5 judge bench who then refers it to a 9 judge bench
- 24th August 2017 – A 9 judge bench rules that the Constitution grants citizen a fundamental right to privacy.

Legal Status of Privacy in India

- The Supreme court of India has held that privacy is a fundamental right that stems from the constitution (*The Puttaswamy judgement*)
- The court has held that as with other fundamental rights, the state may interfere with this right as long as the following four tests are met
 - Legality
 - Legitimacy
 - Proportionality
 - Procedural guarantees

Puttaswamy K.S. and Khanna P. (2012), Justice K.S. Puttaswamy and Mr.Parvesh Khanna v/s Union of India, Writ Petition (Civil) 494 of 2012 in the Supreme Court of India.

The Indian Digital Personal Data Protection Act 2023- Definitions

- “data” means a representation of information, facts, concepts, opinions or instructions in a manner suitable for communication, interpretation or processing by human beings or by automated means;
- “personal data” means any data about an individual who is identifiable by or in relation to such data;
- “personal data breach” means any unauthorised processing of personal data or accidental disclosure, acquisition, sharing, use, alteration, destruction or loss of access to personal data, that compromises the confidentiality, integrity or availability of personal data;
- “digital personal data” means personal data in digital form;

Personal v/s Non Personal Data

- Some data in itself fully identifies an individual
 - Full name
 - A unique id number such as an Aadhaar Number, a passport number, a bank account etc
- Some data on its own may not be sufficient to identify an individual, but if linked with other data, may then identify an individual
 - An IP address
 - A combination of role and company
- It can be seen that personal and non-personal data may not be strict binaries but rather a spectrum. When there is no “reasonable” way to link some data to an individual it may be considered non-personal. However improvements in processing, connectivity and analytic techniques may change the interpretation of what is “reasonable” and that is the challenge

The US Definition

The most commonly used term in the US is Personally Identifiable Information (PII) as defined by NIST is

Any information about an individual maintained by an agency, including (1) any information that can be used to distinguish or trace an individual's identity, such as name, social security number, date and place of birth, mother's maiden name, or biometric records; and (2) any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information.

The EU definition

Personal data is any information that relates to an **identified or identifiable living individual**. Different pieces of information, which collected together can lead to the identification of a particular person, also constitute personal data.

Examples of personal data are

- a name and surname;
- a home address;
- an email address such as name.surname@company.com;
- an identification card number;
- location data (for example the location data function on a mobile phone)*;
- an Internet Protocol (IP) address;
- a cookie ID*;
- the advertising identifier of your phone;
- data held by a hospital or doctor, which could be a symbol that uniquely identifies a person.
- **Note that in some cases, there is a specific sectoral legislation regulating for instance the use of location data or the use of cookies – the ePrivacy Directive (Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 (OJ L 201, 31.7.2002, p. 37) and Regulation (EC) No 2006/2004) of the European Parliament and of the Council of 27 October 2004 (OJ L 364, 9.12.2004, p. 1).*

Examples of data not considered personal data

- a company registration number;
- an email address such as info@company.com;
- anonymised data.
-

https://ec.europa.eu/info/law/law-topic/data-protection/reform/what-personal-data_en#:~:text=Personal%20data%20is%20any%20information,also%20constitute%20personal%20data.

The relationship between Personal Data and Personally Identifiable Information

Personal Data

Information pertaining to person that may or may not on its own be sufficient to identify a person but when linked with other information is capable of identifying a specific person

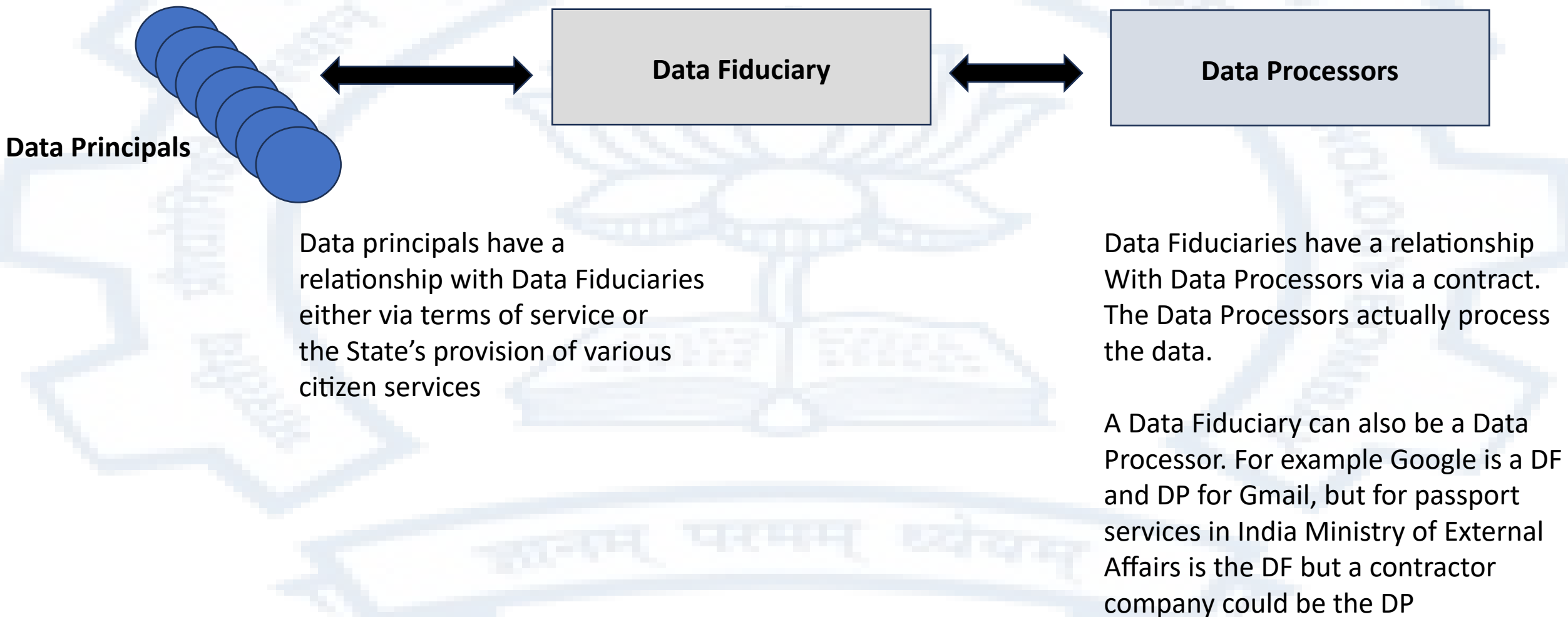
Personally Identifiable Information

Information that can directly identify a specific person

Some Definitions – Indian DPDP Act 2023

- “Data Principal” means the individual to whom the personal data relates and where such individual is—
 - i) a child, includes the parents or lawful guardian of such a child;
 - ii) a person with disability, includes her lawful guardian, acting on her behalf;
- “Data Fiduciary” means any person who alone or in conjunction with other persons determines the purpose and means of processing of personal data
- “Data Processor” means any person who processes personal data on behalf of a Data Fiduciary;

Data Principal – Data Fiduciary – Data Processor



Obligations of Data Fiduciary – DPDPA 2023

Purpose of Processing and Notice

4. (1) A person may process the personal data of a Data Principal only in accordance with the provisions of this Act and for a lawful purpose,— (a) for which the Data Principal has given her consent; or (b) for certain legitimate use

5. (1) Every request made to a Data Principal under section 6 for consent shall be accompanied or preceded by a notice given by the Data Fiduciary to the Data Principal, informing her,— (i) the personal data and the purpose for which the same is proposed to be processed; (ii) the manner in which she may exercise her rights under sub-section (4) of section 6 and section 13; and (iii) the manner in which the Data Principal may make a complaint to the Board, in such manner and as may be prescribed.

Obligations of Data Fiduciary – DPDPA 2023

Consent

6. (1) The consent given by the Data Principal shall be free, specific, informed, unconditional and unambiguous with a clear affirmative action, and shall signify an agreement to the processing of her personal data for the specified purpose and be limited to such personal data as is necessary for such specified purpose.

(2) Any part of consent referred in sub-section (1) which constitutes an infringement of the provisions of this Act or the rules made thereunder or any other law for the time being in force shall be invalid to the extent of such infringement.

(3) Every request for consent under the provisions of this Act or the rules made thereunder shall be presented to the Data Principal in a clear and plain language, giving her the option to access such request in English or any language specified in the Eighth Schedule to the Constitution and providing the contact details of a Data Protection Officer, where applicable, or of any other person authorised by the Data Fiduciary to respond to any communication from the Data Principal for the purpose of exercise of her rights under the provisions of this Act.

(4) Where consent given by the Data Principal is the basis of processing of personal data, such Data Principal shall have the right to withdraw her consent at any time, with the ease of doing so being comparable to the ease with which such consent was given.

(5) The consequences of the withdrawal referred to in sub-section (4) shall be borne by the Data Principal, and such withdrawal shall not affect the legality of processing of the personal data based on consent before its withdrawal

(6) If a Data Principal withdraws her consent to the processing of personal data under sub-section (5), the Data Fiduciary shall, within a reasonable time, cease and cause its Data Processors to cease processing the personal data of such Data Principal unless such processing without her consent is required or authorised under the provisions of this Act or the rules made thereunder or any other law for the time being in force in India

Obligations of Data Fiduciary – DPDPA 2023

Consent – Consent Manager

- (7) The Data Principal may give, manage, review or withdraw her consent to the Data Fiduciary through a Consent Manager.
- (8) The Consent Manager shall be accountable to the Data Principal and shall act on her behalf in such manner and subject to such obligations as may be prescribed.
- (9) Every Consent Manager shall be registered with the Board in such manner and subject to such technical, operational, financial and other conditions as may be prescribed.
- (10) Where a consent given by the Data Principal is the basis of processing of personal data and a question arises in this regard in a proceeding, the Data Fiduciary shall be obliged to prove that a notice was given by her to the Data Principal and consent was given by such Data Principal to the Data Fiduciary in accordance with the provisions of this Act and the rules made thereunder.

Data Principals Rights – DPDPA 2023

11. (1) The Data Principal shall have the right to obtain from the Data Fiduciary to whom she has previously given consent, including consent as referred to in clause (a) of section 7 (hereinafter referred to as the said Data Fiduciary), for processing of personal data, upon making to it a request in such manner as may be prescribed,— (a) a summary of personal data which is being processed by such Data Fiduciary and the processing activities undertaken by that Data Fiduciary with respect to such personal data; (b) the identities of all other Data Fiduciaries and Data Processors with whom the personal data has been shared by such Data Fiduciary, along with a description of the personal data so shared; and (c) any other information related to the personal data of such Data Principal and its processing, as may be prescribed.

(2) Nothing contained in clause (b) or clause (c) of sub-section (1) shall apply in respect of the sharing of any personal data by the said Data Fiduciary with any other Data Fiduciary authorised by law to obtain such personal data, where such sharing is pursuant to a request made in writing by such other Data Fiduciary for the purpose of prevention or detection or investigation of offences or cyber incidents, or for prosecution or punishment of offences.

Data Principals Rights – DPDPA 2023

12. (1) A Data Principal shall have the right to correction, completion, updating and erasure of her personal data for the processing of which she has previously given consent, including consent as referred to in clause (a) of section 7, in accordance with any requirement or procedure under any law for the time being in force.

(2) A Data Fiduciary shall, upon receiving a request for correction, completion or updating from a Data Principal,— (a) correct the inaccurate or misleading personal data; (b) complete the incomplete personal data; and (c) update the personal data.

(3) A Data Principal shall make a request in such manner as may be prescribed to the Data Fiduciary for erasure of her personal data, and upon receipt of such a request, the Data Fiduciary shall erase her personal data unless retention of the same is necessary for the specified purpose or for compliance with any law for the time being in force.

13. (1) A Data Principal shall have the right to have readily available means of grievance redressal provided by a Data Fiduciary or Consent Manager in respect of any act or omission of such Data Fiduciary or Consent Manager regarding the performance of its obligations in relation to the personal data of such Data Principal or the exercise of her rights under the provisions of this Act and the rules made thereunder.

(2) The Data Fiduciary or Consent Manager shall respond to any grievances referred to in sub-section (1) within such period as may be prescribed from the date of its receipt for all or any class of Data Fiduciaries.

(3) The Data Principal shall exhaust the opportunity of redressing her grievance under this section before approaching the Board.

14. (1) A Data Principal shall have the right to nominate, in such manner as may be prescribed, any other individual, who shall, in the event of death or incapacity of the Data Principal, exercise the rights of the Data Principal in accordance with the provisions of this Act and the rules made thereunder. (2) For the purposes of this section, the expression “incapacity” means inability to exercise the rights of the Data Principal under the provisions of this Act or the rules made thereunder due to unsoundness of mind or infirmity of body.

Data Principals Duties – DPDPA 2023

15. A Data Principal shall perform the following duties, namely:—

- a) comply with the provisions of all applicable laws for the time being in force while exercising rights under the provisions of this Act;
- b) to ensure not to impersonate another person while providing her personal data for a specified purpose;
- c) to ensure not to suppress any material information while providing her personal data for any document, unique identifier, proof of identity or proof of address issued by the State or any of its instrumentalities;
- d) to ensure not to register a false or frivolous grievance or complaint with a Data Fiduciary or the Board; and
- e) to furnish only such information as is verifiably authentic, while exercising the right to correction or erasure under the provisions of this Act or the rules made thereunder.

Penalties – DPDPA 2023

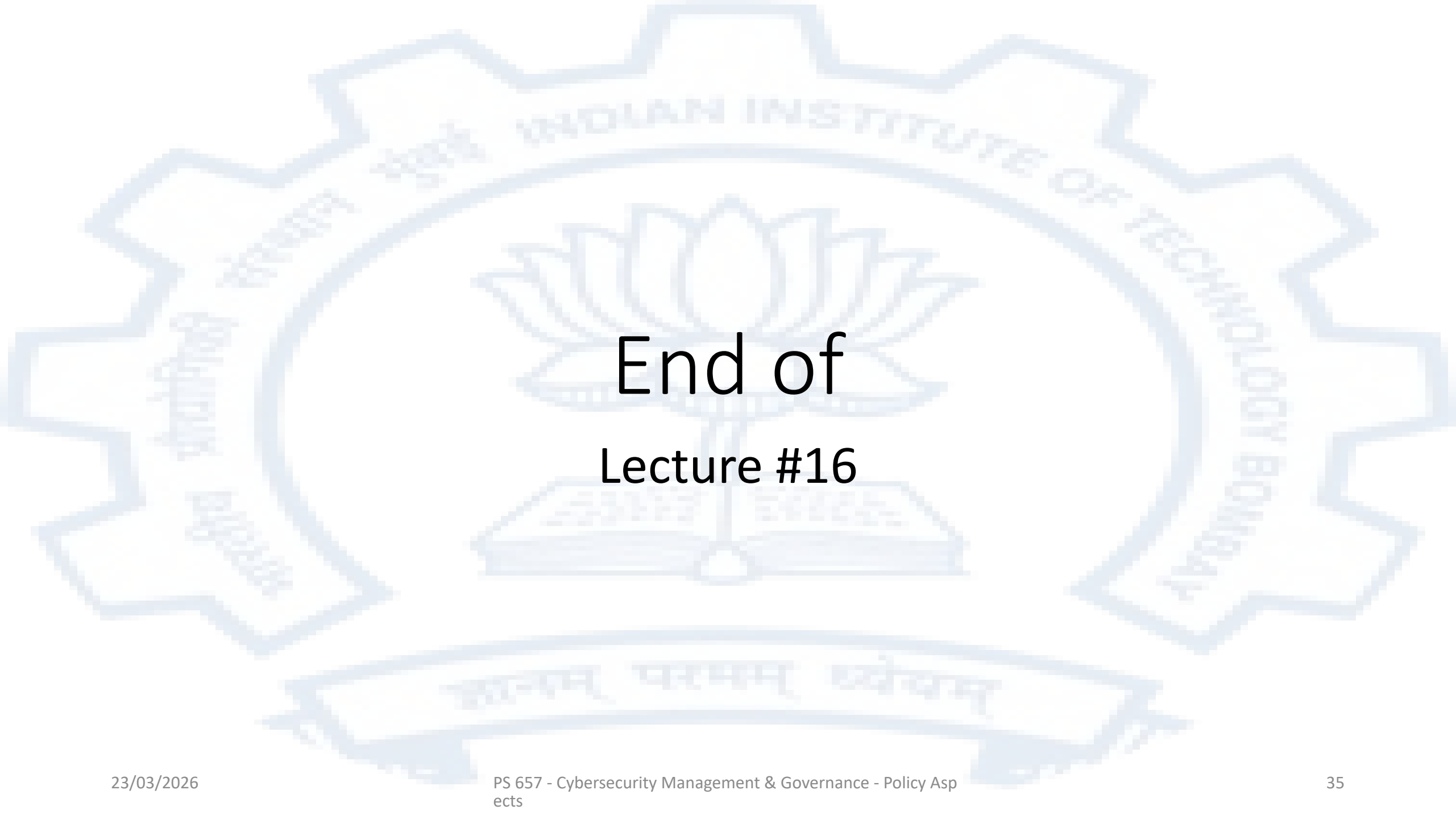
THE SCHEDULE

[See section 33 (1)]

Sl. No.	Breach of provisions of this Act or rules made thereunder	Penalty
(1)	(2)	(3)
1.	Breach in observing the obligation of Data Fiduciary to take reasonable security safeguards to prevent personal data breach under sub-section (5) of section 8.	May extend to two hundred and fifty crore rupees.
2.	Breach in observing the obligation to give the Board or affected Data Principal notice of a personal data breach under sub-section (6) of section 8.	May extend to two hundred crore rupees.
3.	Breach in observance of additional obligations in relation to children under section 9.	May extend to two hundred crore rupees.
4.	Breach in observance of additional obligations of Significant Data Fiduciary under section 10.	May extend to one hundred and fifty crore rupees.
5.	Breach in observance of the duties under section 15.	May extend to ten thousand rupees.
6.	Breach of any term of voluntary undertaking accepted by the Board under section 32.	Up to the extent applicable for the breach in respect of which the proceedings under section 28 were instituted.
7.	Breach of any other provision of this Act or the rules made thereunder.	May extend to fifty crore rupees.

Summary

- Privacy pertains to people.
- Some aspects of the attributes and life of people may be stored as data
- Therefore in many cases a discussion about privacy becomes a discussion about personal data
- The concept of personal data has many interpretations
- There is a narrower concept called personally identifiable information but this concept cannot provide the notion of privacy that is found in many regulations
- The new Indian Digital Personal Data Protection Act 2023 lays emphasis on obtaining consent from individuals before processing their digital personal data
- Standards and best practices may help in defining and using data protection techniques and data management frameworks that are effective

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay (IIT Bombay) logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written along the top inner edge of the gear, and "सत्यमेव जयते" is written along the bottom inner edge.

End of Lecture #16